摘要：

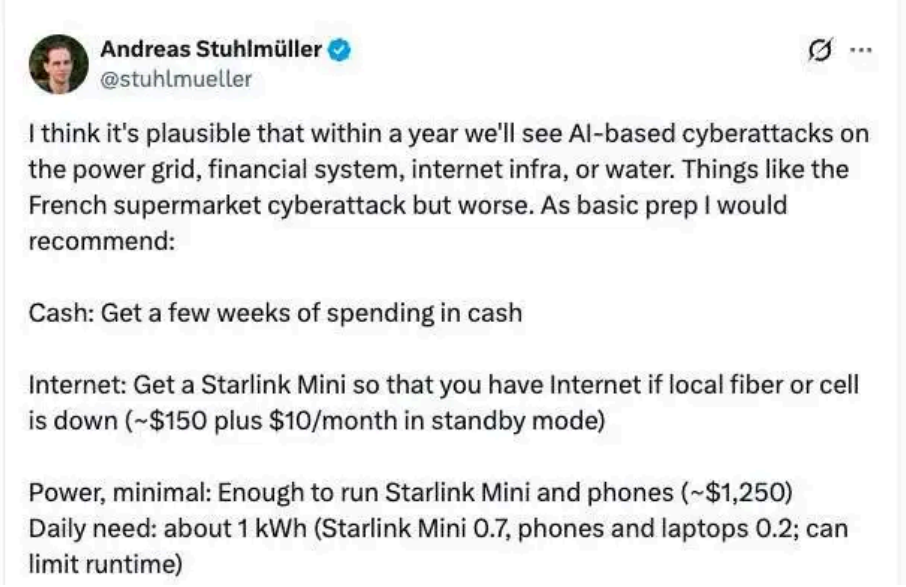
“有这么一个人，世界上大部分 PHP 发行版都靠他一个人维护。如果这个人出了什么事，那就完了。所有人都要遭殃。”

10 月 21 日，全球约七成网站依赖的编程语言 PHP 被曝出两个 CVSS 评分 9.2 的远程代码执行漏洞。各国政府网站下线、医院和学校紧急维护、Cloudflare 在两小时内观测到数十万次攻击尝试。而在补丁得以被数百万台服务器安装之前，一个住在捷克的志愿者，做了最关键的那一步。

## 被提前引爆的危机，埋在结构性失败之上

过去一个月，网络安全专家的公开发言里透着一种少见的恐慌。有人警告，AI 可能引爆一场“黑天鹅”事件；有人被近期集中冒出来的一大批漏洞震住了；还有人担心，Agent 和大语言模型正在展现出发现并利用未知漏洞的能力。

这些声音，轻一点的，是老生常谈的安全建议——及时更新软件、开启双重验证；重一点的，则在网上含糊地谈论 AI 驱动的攻击，感叹“互联网曾经很美好”，甚至流露出末日求生式的恐慌：劝人从银行取出现金、断开网络、囤积耐储存的食品和饮用水、把钱换成黄金和现金，再买一台手摇应急收音机。




约翰斯·霍普金斯大学教授、全球最受尊敬的密码学家之一 Matthew Green 发帖说：“我们正处在电影里的那个桥段：手边能找到的东西，全往僵尸面前扔，只求拖慢它们的脚步。”他还写道：“越来越多人发现，整个互联网就像一堆干透的引火物，之所以还没烧起来，只是因为那些青少年还没找到火柴。”










这些帖子出现的时候，用 AI 工具发现 PHP 漏洞的人还没动手。PHP 是支撑互联网许多部分运行的编程语言。最近几天，重大漏洞和安全问题接连浮出水面，涉及印度网站安全证书提供商 eMudhra、PHP 的替代方案 Node.js、软件开发平台 GitLab、云服务提供商 Railway，以及编程 Agent 平台 OpenCode 等公司和服务，另有多家公司和服务也受到波及。不过，最受关注的仍是 PHP 漏洞，研究人员把它称作 PHP2Shell。Wiz、Calif 和 OpenAI 的研究人员借助 AI 发现了这些漏洞。

Cloudflare 的首席执行官 Matthew Prince 所在的公司，能够大范围观察互联网的整体运行状况。他在网上写道：“在 PHP2Shell 公开公布前的 10 个小时里，Cloudflare 网络观察到数千次漏洞利用尝试。漏洞公布后的 45 分钟内，尝试次数增至数万次；两小时内达到数十万次，现在已经有数百万次。”

这组数字背后，是一场被提前引爆的危机。PHP 安全团队原本计划在次日发布两个严重漏洞的修复补丁，两个漏洞都允许未经身份验证的攻击者在服务器上执行任意代码——安全界所谓“最坏的那一类”：不需要密码，不需要特殊权限，攻击者可以直接接管服务器。

但漏洞信息在补丁发布前遭到泄露，一段概念验证的攻击演示视频开始在网络上流传——不过当时还没有任何技术细节泄露。这段演示来自软件供应链安全公司 Chainguard。

据其 CEO 的说法，他们用公司的 AI Harness 和一个前沿模型，发现了同一批内存破坏类漏洞，所用的提示词不过是一个“基础指令：‘找出 PHP 中的严重漏洞’”。随后，Chainguard 开始与 PHP 维护者合作，确认自己发现的部分问题与漏洞报告相符，并协助测试补丁。“这些补丁非

常复杂——这绝不是一个简单的漏洞，他们确实花了好几个月，才做出真正可用的补丁。到了周一，传言开始出现；昨天，事情就彻底失控了。”

**他还说：“只要知道某款软件存在漏洞，哪怕它像 PHP 这样庞大复杂，也足以让我们把漏洞找出来。我认为，这很快会成为常态：人们几小时内就能开发出漏洞利用程序，甚至还没弄清漏洞具体藏在哪里。”**

## 补丁背后，是一个志愿者

PHP 项目被迫把发布时间从原定的周四提前到周三，留给全球系统管理员的时间窗口被压缩了整整一天。

后果来得极快。德国联邦信息技术中心预防性关闭了多个政府网站，芬兰、法国、比利时等国对公共部门网站采取保护措施，美国 CISA、欧盟 CERT-EU、英国 NCSC 相继发布紧急警告。CERT-EU 在公告中特别指出，许多商用和开源产品以 PHP 作为后端，即使不直接对外提供 PHP 服务也可能受影响。

而在这一切背后，还有一个更令人不安的事实：PHP Foundation 后来承认，其中一个漏洞的修复工作早在 2024 年的一次外部安全审计中就已发现线索，但由于资源不足、决策流程低效、能够深入理解 PHP 引擎内部机制的人太少，修复被拖延了近两年。基金会自己在事后声明中将此称为“结构性失败”。

这个“结构性失败”并没有因为这次危机而被解决。在 Reddit 和 X 上，恐慌之中有一个名字被反复提起：Ondřej Surý。在这之前，没多少人听过这个名字。




软件开发者 Ian Landsman 在 X 上写了一段后来被广泛引用的话：“我跟妻子解释，有这么一个人，世界上大部分 PHP 发行版都靠他一个人维护。如果这个人出了什么事，那就完了。所有人都要遭殃。”




这话有夸张的成分，但离事实并不远。Surý 不住在硅谷，也不在 PHP Foundation 领取薪水。他的正式工作是 Internet Systems Consortium 的 DNS 工程总监。维护 PHP 软件包是他的志愿

工作。

他做的事情，是把 PHP 项目发布的源代码“打包”成可以直接安装在服务器上的软件包，并让这个过程尽可能自动化。没有这一步，全球大量使用 PHP 的网站运营者——包括那些不具备从源码编译技能的人——将不得不在漏洞公开后手忙脚乱地自行处理。

**过去 48 小时里，他无疑成了整个互联网的幕后英雄之一。而这份志愿工作，长期以来只靠一些数额不大的捐款支撑。一位 PHP Subreddit 用户写道：“Ondřej 今天会拯救互联网。”**

变化来得很快。这 24 小时里他收到的捐款，差不多抵得上过去一整年。用他的话说，过去从没见过这样的阵仗。

## 大西洋月刊专访

以下对话译自《大西洋月刊》，记者为 Charlie Warzel，受访者为 Ondřej Surý。

**Charlie Warzel：请用通俗的话告诉我，过去 72 小时里发生了什么。**

Ondřej Surý： 本周早些时候，PHP 项目通知我，代码里存在一个严重的安全漏洞。到了周二，大家发现有人泄露了即将公布的漏洞信息。PHP 项目内部决定加快发布流程，把原定周四发布的时间提前到周三。事情从这时开始变得有些疯狂，因为我们突然少了一天时间。

**Warzel：我试着把这件事放到更大的背景里理解：PHP 这门支撑着互联网运行的编程语言，最多被 70% 的网站使用？**

Surý： 我听到的也是这个比例。

**Warzel：人们会寻找网络安全漏洞，目的未必是为了发动攻击，也可能只是为了防御。有人发现漏洞，这本身不算特别反常。真正的问题是，这次漏洞披露的范围很广，而网站运营者在修补漏洞之前能用的时间又很短，对吗？**

Surý： 我想补充一点：关键在于漏洞的严重程度，这次的严重程度很不寻常。远程代码执行是最严重的漏洞类型，因为攻击者可以在运行 PHP 的服务器上执行自己的代码。这就是它为什么会在整个互联网上引发恐慌。正如你所说，如果大约 70% 的网站都在运行 PHP，而攻击者真的能在这些服务器上执行代码，影响就会非常巨大。

**Warzel：你说，尽管网上一片恐慌，这 48 小时对你来说并不算特别疯狂。从外界看来，这很令人意外。我不断看到有人说：“只有一个人负责修复这个漏洞，而且他靠 Patreon 养活自己。”这话可能有些夸张，但也有几分真实：你的工作几乎相当于一个人在帮助数百万人。为什么你会觉得这段时间并不疯狂？**

Surý： 有几个原因。首先，我做这件事已经很久了，超过 20 年。我做的很多事情都已经实现了自动化。这次对我来说并不疯狂，还有一个原因：我自己其实没有任何运行 PHP 的系统。所以对我而言，事情大概就是：“好，我对互联网用户负有责任。”如果当时我正在亚得里亚海中央的一艘船上，那一天可能就会很疯狂。这种情况确实有可能发生。但这次我有时间准备软件包。

**Warzel：这还挺不可思议的。**

Surý： 就算没有我，大家仍然可以从其他渠道获取 PHP，然后自己编译。但对所有人来说，过程会复杂得多，有些人也不具备立即升级 PHP 的技能。PHP 项目发布的是这门语言的源代码，而我做的工作，是把源代码打包成可以安装到服务器上的软件包。这样非常方便，也更快，还能自动化。你可以把同一个软件包安装到数百台、数千台服务器上，不需要自己编译。

如果我当时无法参与，整个过程就会花更长时间，有些人也不具备所需的技能。真正值得感谢的，是 PHP 项目把我纳入了那个知情的小圈子，让我能在漏洞公开前就获知情况并提前准备。

**Warzel：收到邀请时，你有没有觉得“糟了”？**

Surý： 我现在的人生阶段，大概会想：“这很糟糕，必须修好。”但至少对我来说，这不会引发恐慌。很多人确实因此慌了起来。可我的想法更像是：“现在出了状况，需要解决，解决的方法也明确了。我有时间做好准备。”如果我没有时间做好准备，压力就会大得多。从我的角度来看，这件事没那么令人紧张，因为我做的是志愿工作。如果我被公交车撞了，那就会变成其他人的问题。

**Warzel：每次我稍微写一些网络安全和开源软件领域的内容，就会发现有一些维护者在承担这些工作，比如你这样因为在意这件事而付出的人。很多时候，没人知道他们的名字。如果有一天你真的被公交车撞了，有人能接手你的工作吗？**

Surý： 我确实在考虑应急方案，也正在和软件公司 Freexian 的 Raphaël Hertzog 沟通。我的优势是经验丰富，知道该动哪里才能让事情正常运转。但 Freexian 也有很多专业经验，如果我出了什么事，他们能够接手。从昨天开始，人们陆续捐了很多钱，有小额捐款，也有较大金额的捐款。我想感谢所有人。

**Warzel：捐款多到让你应接不暇了吗？**

Surý： 还没到硅谷那种级别，不过我收到的捐款确实相当可观，过去从来没有见过这样的情况。过去一年收到的捐款，差不多在这 24 小时里就收到了。

**Warzel：如果这次没有这么快修补漏洞，会发生什么？**

Surý： 可能发生很多事。最基本的情况是网站遭到破坏或被打瘫。如今我们每天都能在互联网上看到这种情况。另一种可能是有人获得访问权限，把这些设备组成僵尸网络。我觉得现在主要是有组织犯罪团伙在做这类事，已经不是某个躲在地下室里、出于好玩而动手的小年轻了。他们有经济动机，可以把僵尸网络服务卖出去，也可以利用这些服务器挖加密货币赚钱。而且这些事情仍有可能发生，因为并非所有人都已经修补漏洞并升级 PHP。

**Warzel：我在 X 上看到一条帖子，说并非所有 PHP 版本都能打上补丁，互联网有三分之一可能已经永久损坏或存在漏洞。这说法准确吗？**

Surý： 最初流传的这个说法并不准确。老版本也有办法打补丁。

**Warzel：所以互联网有三分之一永久完蛋了，这种说法不对。好。**

Surý： 对，不准确。如果用户足够重视，他们也能升级这些旧版本的 PHP。

**Warzel：现在是网络安全领域一个令人恐惧的时刻。我看到有人把这次漏洞和其他 AI Agent 攻击称为“黑色十月”。人们担心，无论是防御型 Agent 还是攻击型 Agent，都能发现这些漏洞。我注意到，网络安全社区有一种感觉：他们一直担心，漏洞被利用或被发现的速度会快到人们**

**应付不来，而那个未来正在变成现实，我们已经身处其中。与此同时，也有一部分人认为攻防之间会形成一种平衡：如果有持续行动、善于识别和利用漏洞的 Agent，也会有持续行动、善于防御漏洞的 Agent。**

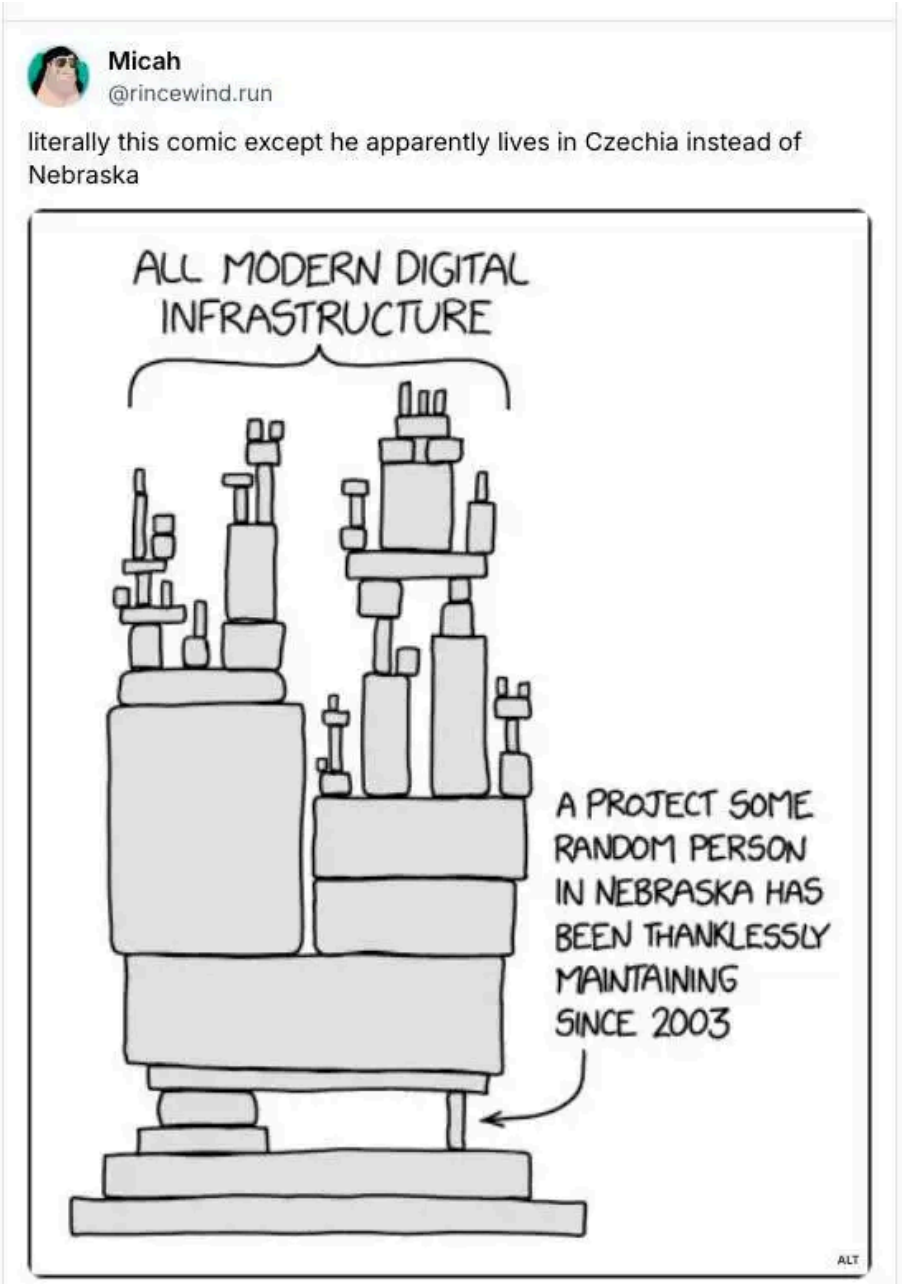
Surý： 我们已经看到事情加速了，这一点完全没错。防御者也能够使用大语言模型来主动发现漏洞。我认为，问题归根结底很简单：人们往往把 IT 基础设施当成理所当然的东西。

很多地方都没有把足够的优先级和资金投入到 IT 基础设施维护中。受影响的不只有企业，还有很多已经过时的消费电子设备，它们同样会遭到攻击。我同意现在一切都在加速，这给负责防御的人带来了沉重负担。同时，也许这次事件会成为一个转折点，让我们开始真正重视这件事。

**Warzel：你觉得这种转变真的会发生吗？**

Surý： 我可能会判断错，但我还是个乐观主义者，相信人们最终会意识到，我们不能永远这样下去。很久很久以前，这场灾难就已经在酝酿了。眼下发生的事情只是一次警钟，未来还会有更多警钟。

**Warzel：我很惊讶，互联网某些领域的基础设施，竟然能依赖一两个人。这种脆弱性令人担忧。你希望看到什么变化？**




Surý： 我刚开始做开源时，觉得这很有意思。现在某种程度上也仍然如此。但周围的环境已经变了。开源有时让人觉得自己正在被利用。我希望找到一种新的模式，让那些从开源工作中获益最多的人，能够为开源工作者付出的时间和劳动提供回报。我希望企业意识到，这是一种剥削。任何剥削都无法持续。如果这种情况继续下去，最后会酿成糟糕的结果，因为从事开源工作的人最终会失去继续投入的动力。

**Warzel：听起来你对这一切并不太在意个人名声。不过，昨天你做了很多工作，帮助了世界各地的大量用户。昨晚躺下时，知道自己发挥了这样的作用，你有什么感受？**

Surý： 我妻子说我情感上已经麻木了，但其实没有。那种感觉很好。看到社交平台上满是感谢我的留言，收到感谢邮件，都会让我觉得很开心。这让我做的事情有了意义。我觉得自己的工作是有价值的。

**Warzel：整个互联网都感谢你的付出。此刻，你有什么建议想给普通用户，帮助他们提升网络安全意识吗？**

Surý： 我建议大家相信专家。在危机中，我们都会这么做：向专家请教，并信任他们。相信那些负责维护这些系统的人，知道自己在做什么。我们能做的就是这些。

本文来源：InfoQ

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。




限免

335 收藏 分享到:

写评论

请发表您的评论

表情 图片 发布评论